



File No.: EXP202302073

RESOLUTION OF

PROCEDURE OF WARNING

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A., B.B.B., and C.C.C. (hereinafter, the claiming parties) respectively submitted written complaints to the Spanish Agency for Data Protection on January 5, 6, and 10, 2023. The complaints were directed against D.D.D. with NIF ***NIF.1 (hereinafter, the claimed party).

The complainants stated in their writings that they received an email on January 4, 2023, from the address ***EMAIL.1, which included multiple email addresses as recipients, among which were the addresses of the complainants themselves, and in which the email addresses of the other recipients to whom it was addressed were visible.

They claim that the mentioned email addresses are visible because the BCC functionality was not used in the aforementioned email, which allows for the concealment of recipients.

Along with these complaints, a copy of the mentioned email dated January 4, 2023, was provided, where approximately 151 email addresses are listed as recipients, including the email addresses of the complainants, with the subject "COMMUNICATION REPLACEMENT SHOW SHEA COULEÉ BARCELONA" and sent from the address ***EMAIL.1.

SECOND: On February 17, 2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted by the claiming party was admitted for processing.

THIRD: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

- Taking into account the sender of the email subject to the complaints, a consultation was made regarding the ownership of the domain (...), revealing that it was registered with IONOS CLOUD S.L.U. on January 28, 2020, and that it is associated with a web hosting service called "MyWebsite Creator," by the IONOS client whose details correspond to the claimed party D.D.D. with NIF ***NIF.1, residing at ***ADDRESS.1.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/8

-

By virtue of such information, on 4/5/2023, the Data Inspection requested from the responding party information and documentation regarding the facts presented in the complaint, to which it responded through a written submission dated 16/5/2023, highlighting the following:

- That, in her capacity as a self-employed worker, she carries out the activity of organizing and managing events, under the brand (...).

- She states that in the context of her activity, she collaborated in the organization of an event that was to take place in 2020, which had to be postponed due to the measures adopted in response to Covid-19. When a new date for the postponed event was subsequently established, it became necessary to communicate this to all the clients who had previously purchased their tickets. For this purpose, the main organizer of the event, WEEZEVENT SAS, requested her to send the communication to the clients as they were unable to send it due to technical issues.

- On 4/1/2023, she proceeded to send two emails to the aforementioned clients with the email addresses hidden, copies of which she provides, to inform them of the new date of the event; one sent from the address (...) and another from the address ***EMAIL.1. This second email was sent with the

aim of providing the clients with an email address to reply to or request additional information.

However, she states that the email sent from ***EMAIL.1 reported an error, indicating that the email could not be delivered to the recipients, of which she provides a copy for evidentiary purposes.

- Following these circumstances, she states that she prepared a third email from ***EMAIL.1, which is the subject of the complaints filed, and which, due to an error stemming from her concern that the clients would ultimately receive the information, she placed the addresses in the "CC" field instead of "BCC," allowing the email addresses of the other recipients to be visible.

- She explains that hours later, after sending the email, she received responses from three clients informing her of the error committed, warning that the email had been sent with visible copies. Upon detecting this fact, she individually replied to the clients who notified her of the error, offering her individual apologies to each one, providing copies of two of these emails as evidence of this fact. Additionally, she later prepared and sent another email, a copy of which she also provides, this time placing the addresses in blind carbon copy (BCC) to all recipients, apologizing to all of them and expressing regret for the error made.

- She states that the events occurred as a result of a human error, made involuntarily, adding that it is not part of her activity to carry out this type of mass communication, being, in fact, the first time she had done so.

- For her part, she claims that she has no knowledge of the use by third parties of the personal data obtained, consisting of the email addresses.

- Regarding the security of the processing of personal data, she provides a copy of the risk analysis dated 15/9/2022, which includes the processing subject to the complaint, in which the risk of sending was anticipated.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/8

mass communications, assessing the inherent threat of sending communications to multiple recipients. The analysis determined that, since this activity was not being carried out, the initial risk was low. The measures include the obligation to use blind carbon copy (BCC), and to contract, if necessary, a mail-marketing tool that would mitigate the risk of errors if this activity needed to be repeated or could be considered habitual.

□

Regarding the measures adopted to prevent the incident from recurring, it is evidenced that a mail-marketing tool was contracted for the sending of communications in case its activity was forced to urgently carry out a similar communication, thus ensuring the sending in blind carbon copy.

FIFTH: On September 15, 2023, the Director of the Spanish Agency for Data Protection decided to initiate a warning procedure against the complained party, for the alleged infringement of articles 5.1.f) and 32 of the GDPR, classified in articles 83.5 and 83.4 of the GDPR, respectively. In this agreement, a period of ten working days was granted for the complained party to submit allegations and present any evidence deemed appropriate.

SIXTH: The notification of the aforementioned initiation agreement, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), took place electronically on 09/15/2023, as evidenced by the acknowledgment of receipt in the file.

SEVENTH: On 09/26/2023, this authority received a written communication from the complained party, in which it expressed its agreement with what was stated by the AEPD, as well as its commitment to comply with the security measures already implemented, as well as to adopt all appropriate technical and organizational measures to ensure unauthorized processing.

In view of all that has been acted upon, the following facts are considered proven by the Spanish Agency for Data Protection in the present procedure,

PROVEN FACTS

FIRST: From the instruction of this procedure, as well as from the investigative actions and the

documents in the file, it is evidenced that an email was sent on January 4, 2023, from the address ***EMAIL.1, an address that was intended for a plurality of recipients, among which were the complaining parties, and in which the email addresses of the other recipients to whom it was addressed could be visualized. The email addresses appeared visible because the BCC functionality was not used in the aforementioned email, which allows each recipient to remain unaware of the other recipients.

THIRD: Likewise, it is evidenced that the mentioned address ***EMAIL.1 through which the email subject to this procedure was sent, is linked to the domain (...), which is owned by the complained party, through a web hosting service.

SECOND: Such facts have also been confirmed by the complained party, which stated during the instruction of this procedure that they occurred due to a human error of an involuntary nature.

FOURTH: During the investigative actions, the complained party has stated that it has taken measures to prevent the aforementioned facts from recurring. Specifically, it is evidenced that a mail-marketing tool has been contracted for the purpose of sending communications and that allows ensuring the sending in blind carbon copy.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, and 64.3 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Unfulfilled Obligations

Article 5 of the GDPR establishes the principles relating to processing, indicating, among other issues, that personal data shall be:

"f) processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')."

Similarly, Article 32 of the GDPR expressly refers to the security of processing:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying risks of probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk."

5/8

appropriate organizational measures to ensure an adequate level of security relative to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regular verification, evaluation, and assessment of the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration will be given to the risks presented by the processing of data, particularly as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data."

In this case, it has been established that the respondent sent an email to multiple recipients without concealing their addresses, which allowed the addresses of others to be visible, thereby violating the confidentiality principle provided for in the aforementioned Article 5.1 f) of the GDPR regarding the processing of personal data.

In this regard, to ensure this principle, the respondent should have adopted the relevant prior technical or organizational measures of all kinds that ensured adequate processing and prevented unauthorized or unlawful processing.

On the other hand, the respondent, as the data controller of such data, should have adopted technical and organizational measures that ensured an adequate level of security relative to the risk, which, however, were not implemented. The absence of measures to ensure the level of security demonstrates non-compliance with the provision of Article 32 of the GDPR, since the considerable number of recipients to whom the email was addressed posed a risk that required the adoption of appropriate measures to prevent a personal data breach, as occurred in this case.

III

Classification and Qualification of the Violations

On one hand, the non-compliance with the confidentiality principle provided for in the aforementioned Article 5.1.f) of the GDPR constitutes an infringement attributable to the party D.D.D., as provided in Article 83.5 of the same regulation, which expressly states:

“Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent in accordance with Articles 5, 6, 7, and 9;”

For the purposes of the statute of limitations for infringements, this infringement is subject to a three-year limitation period, in accordance with Article 72.1.a) of the LOPDGDD, which qualifies the following conduct as very serious:

“a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679.”

On the other hand, the failure to adopt the technical and organizational measures to ensure an adequate level of security relative to the risk as provided in Article 32 of the GDPR constitutes an infringement as provided in Article 83.4, which states, “Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor in accordance with Articles 8, 11, 25 to 39, 42, and 43;”

For the purposes of the statute of limitations for infringements, the alleged infringement is subject to a two-year limitation period, in accordance with Article 73 f) of the LOPDGDD, which qualifies the following conduct as serious:

“f) The failure to adopt those technical and organizational measures that are appropriate to ensure an adequate level of security relative to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679.”

IV

Warning

Without prejudice to the provisions of Article 83 of the GDPR, the aforementioned Regulation provides in paragraph 2.b) of Article 58 “Powers” the following:

“Each supervisory authority shall have all of the following corrective powers indicated below:

(...)

b) issue a warning to any controller or processor when the processing operations have infringed the provisions of this Regulation; (...)”

Furthermore, Article 64 of the LOPDGDD, which regulates the “Form of initiation of the procedure and duration,” in its third paragraph states that:

“3. When appropriate, taking into account the nature of the facts and duly considering the criteria

established in Article 83.2 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, the
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/8

The Spanish Agency for Data Protection, after hearing from the data controller or processor, may issue a warning, as well as order the data controller or processor to adopt corrective measures aimed at ending the possible non-compliance with data protection legislation in a specific manner and within the specified timeframe.

The procedure shall have a maximum duration of six months from the date of the initiation agreement. After this period, it will expire, and consequently, the proceedings will be archived.

The provisions of the second and third paragraphs of section 2 of this article shall apply in this case. In this case, given the circumstances resulting from the instruction of this procedure and following the criteria of the indicated provisions, this authority deems it appropriate to issue a warning to the party being complained about.

V

Adoption of measures

Considering that, as indicated in the proven facts, the party being complained about has demonstrated the adoption of technical and organizational measures to prevent the recurrence of the facts subject to this procedure, this authority does not consider the imposition of new measures on the party being complained about, without prejudice to the maintenance of those already adopted.

Therefore, in accordance with the applicable legislation and evaluated the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO ISSUE A WARNING to D.D.D., with NIF ***NIF.1, for an infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, as well as Article 32 of the GDPR, classified under Article 83.4 of the same regulation.

SECOND: TO NOTIFY this resolution to D.D.D.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

8/8

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal.

If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also

provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension would be considered concluded.

1403-021023

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es